sabsa-breb.pdf

ARQUITECTURA DE SEGURIDAD SABSA PARA PAGOS INMEDIATOS BRE-B

NovaPay S.A. // Proyecto: Vinculación a Bre-B como participante

```
$ ./sabsa --empresa novapay --proyecto bre-b
> capas contextual..component ...... ok
> matriz SABSA (xlsx) ............... ok
```


> equipo

Sergio Andrés Caceres Díaz
Over Haider Castrillón Valencia
Michael Steven Pinilla Mateus

Universidad del Rosario

MISIÓN Y VISIÓN DE LA EMPRESA

Universidad del Rosario

$ cat /etc/novapay/{mision,vision}

> mision.txt

Facilitar que personas y comercios en Colombia muevan su dinero de forma **inmediata**, **segura** y **sin costo** desde el celular, protegiendo la **confianza** de los clientes.

> vision.txt

Ser en 2030 la billetera digital preferida por quienes hoy usan efectivo, reconocida por la seguridad de sus pagos.

> objetivo_estrategico_2027

Duplicar los clientes activos en 2027 **sin aumentar el fraude**.

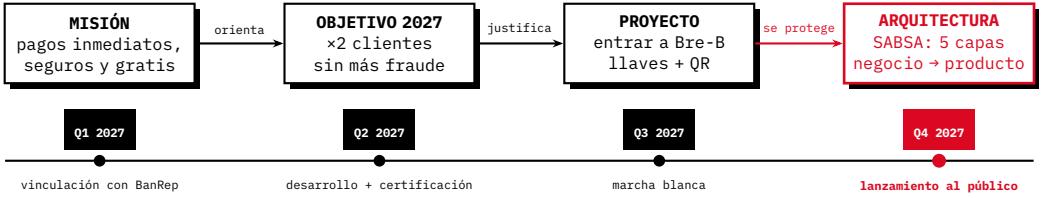
NovaPay S.A.: compañía de financiamiento digital vigilada por la SFC.

OBJETIVO DEL PROYECTO

$ sabsa init --proyecto bre-b --dueño "Gerencia de Pagos Inmediatos"

> objetivo.txt

Vincular a NovaPay S.A. a **Bre-B** como participante (vía un sistema de pago certificado) y lanzar en la app las transferencias por llaves y los pagos QR (**24/7**, **< 20 s**), con la seguridad incluida desde el diseño.



Universidad del Rosario

$ sabsa --layer contextual --view business --owner "Junta + Presidencia"

WHAT — objetivos

> Transferencias y QR en la app.
> Captar a quien usa efectivo.
> Fondos y datos protegidos.

WHY — oport. / amenazas

> + Crecer: 110 M de llaves en Bre-B.
> + Comercios QR y marca segura.
> — Fraude, caídas y sanciones.

HOW — procesos

> Vinculación con BanRep.
> Desarrollo, pruebas y aceptación.
> Fraude, conciliación, servicio al cliente.

WHO — sponsors

> Junta, Presidencia, VP Comercial.
> Dueño: Gerencia de Pagos Inmediatos.
> **CISO transversal** (reporta a Presidencia).

WHERE — sitios

> Sede en Bogotá.
> Centro de datos principal + alterno.
> Banco de la República (contraparte).

WHEN — tiempos objetivo

> **Lanzamiento: Q4 2027.**
> ×2 clientes a dic-2027.
> 24/7 y < 20 s desde el día 1.

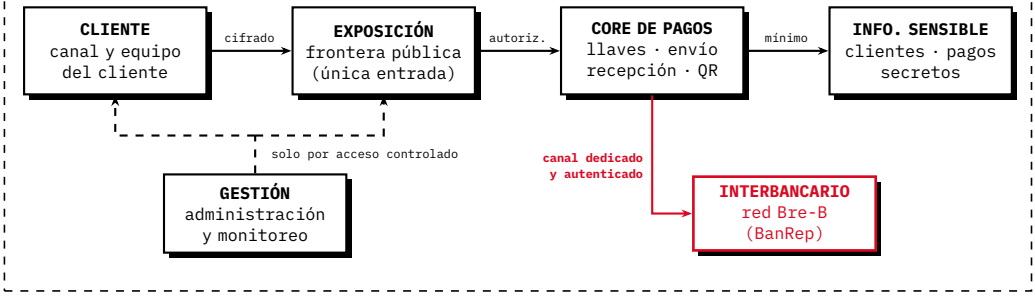
[BanRep CRE DSP-465 (v. 31-mar-2026) · SFC CBJ (CE 006/2025)]

Universidad del Rosario

$ sabsa --layer conceptual --view architect --owner "CISO + directores de área"

atributos | **DISPONIBLE** | **CONFIDENCIAL** | **ÍNTEGRO** | **AUTENTICADO** | **NO REPUDIABLE** | **ANTIFRAUDE**

ZERO TRUST + DEFENSA EN PROFUNDIDAD — + privacy by design · DevSecOps · IA gobernada

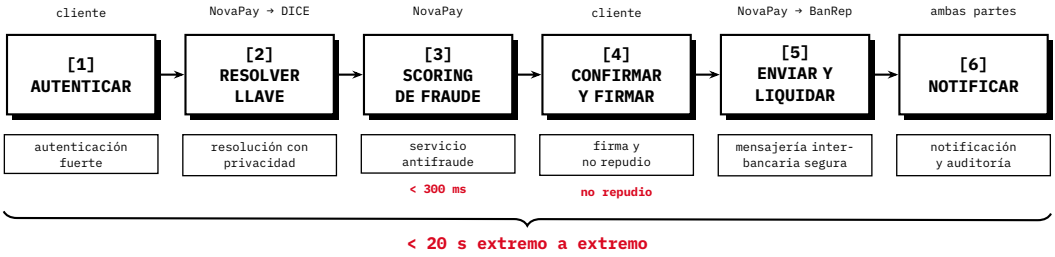


dueños VP Pagos (proceso) · CISO (riesgo ciber) · Gte. Fraude (riesgo de fraude)

normas ISO 27001 · ISO 42001 (IA) · NIST CSF 2.0 + SIAR · SFC · BanRep · Ley 1581

Universidad del Rosario

$ sabsa --layer logical --view designer --owner "CISO + Arquitecto de Seguridad"



PERFILES	cliente: sus llaves	agente: datos enmascarados	analista: retener/liberar	ingeniero: JIT	auditor: solo lectura	
POLÍTICAS	MFA fuerte	bloqueo 24 h tras cambio de SIM	todo canal cifrado	sesión 5 min · token 10 min		

$ sabsa --layer physical --view builder --owner "Dir. Infraestructura"

WHAT — datos

> Restringido: tokenizado.
> Confidencial: cifrado.
> Catálogo con dueño y retención.

WHY — reglas

> Reglas de fraude (velocidad, mula).
> Playbooks ATO, DDoS, ransomware.
> Parches críticos en 7 días.

HOW — mecanismos

> Passkeys FIDO2 + device binding.
> WAF, anti-DDoS, service mesh.
> HSM/KMS, tokenización, SIEM.
> DLP en endpoint (shadow AI).

WHO — acceso

> SSO + llave FIDO2 interna.
> RBAC + ABAC (monto, horario).
> PAM con sesiones grabadas.

WHERE — red

> VPC por ambiente.
> Subred por dominio.
> 3 zonas + región alterna.

WHEN — tiempos

> **Pagos: RPO 0**; RTO $\leq$ 2 h por región.
> Caída de zona: $<$ 1 min.
> Copias inmutables aisladas.

Universidad del Rosario

$ sabsa --layer component --view tradesman --owner "Líder SecOps"

↓ internet · app · comercios

PERÍMETRO	Cloudflare: WAF · anti-DDoS · bots	API Gateway			
IDENTIDAD	Auth0 / Keycloak	Entra ID + YubiKey	CyberArk (PAM)		
PLATAFORMA	EKS 3 AZ + DR	Istio (mTLS)	Aurora	MSK (Kafka)	
CRIPTO	CloudHSM	KMS	HashiCorp Vault		
DETECCIÓN	Feedzai (fraude)	Sentinel (SIEM)	Purview DLP		
PIPELINE	GitHub Actions	Semgrep	Snyk	Trivy	ZAP

agenda

> pentest trimestral
> escaneo semanal y en cada build
> DRP semestral
> tabletop anual de ransomware
> Vault: rotación diaria; certs 90 d
> NTP en todo nodo

CONCLUSIONES

- **El negocio manda:** El proyecto existe porque mueve un objetivo estratégico; la arquitectura alinea ese objetivo con la tecnología y justifica cada peso invertido.
- **De lo general a lo particular:** Se bajó desde lo que pide el dueño del negocio hasta los productos, de arriba hacia abajo y de izquierda a derecha, y cada producto se puede rastrear hasta un requisito.
- **La seguridad es transversal:** No es un área de Tecnología sino un componente que toca a todas las áreas; por eso el CISO reporta a Presidencia.
- **Lo que sigue:** La sexta capa de SABSA (operación) toma esta arquitectura para operarla y medirla en el día a día: monitoreo, incidentes e indicadores de riesgo.

Arquitectar = llevar el objetivo de negocio hasta los controles

$ sabsa --preguntas

¿PREGUNTAS?



NovaPay S.A. // Vinculación a Bre-B como participante